

Air University



SSDD (Lab)

Year 2026

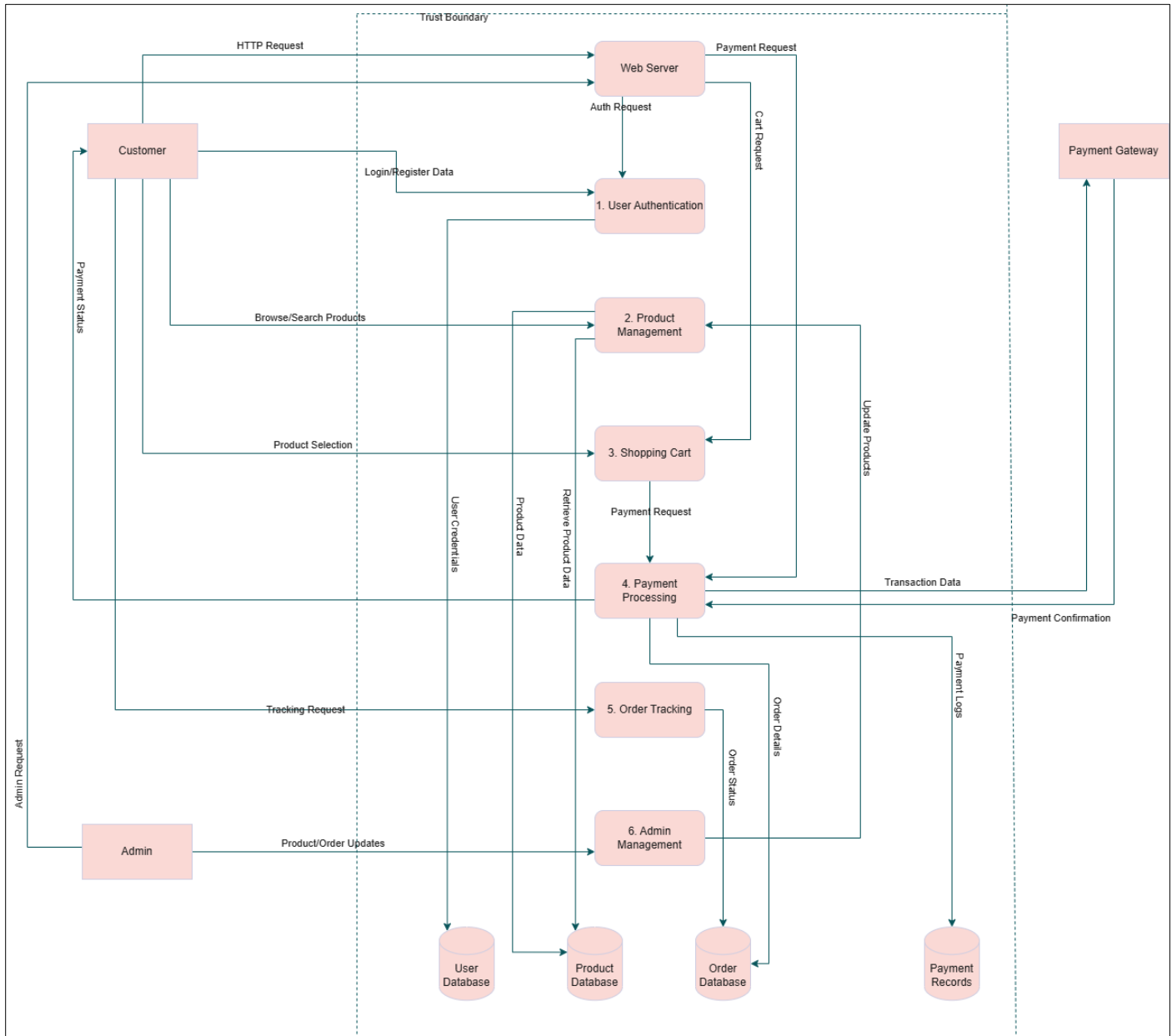
Mr. Anjum Rehman

Academic Year: 2024 – 2028
Department of Cyber Security

USAMA ARSHAD | 247141
BS – Cyber Security – Fall – 24 (A)
Date of Submission: May 16, 2026

Quiz # 03

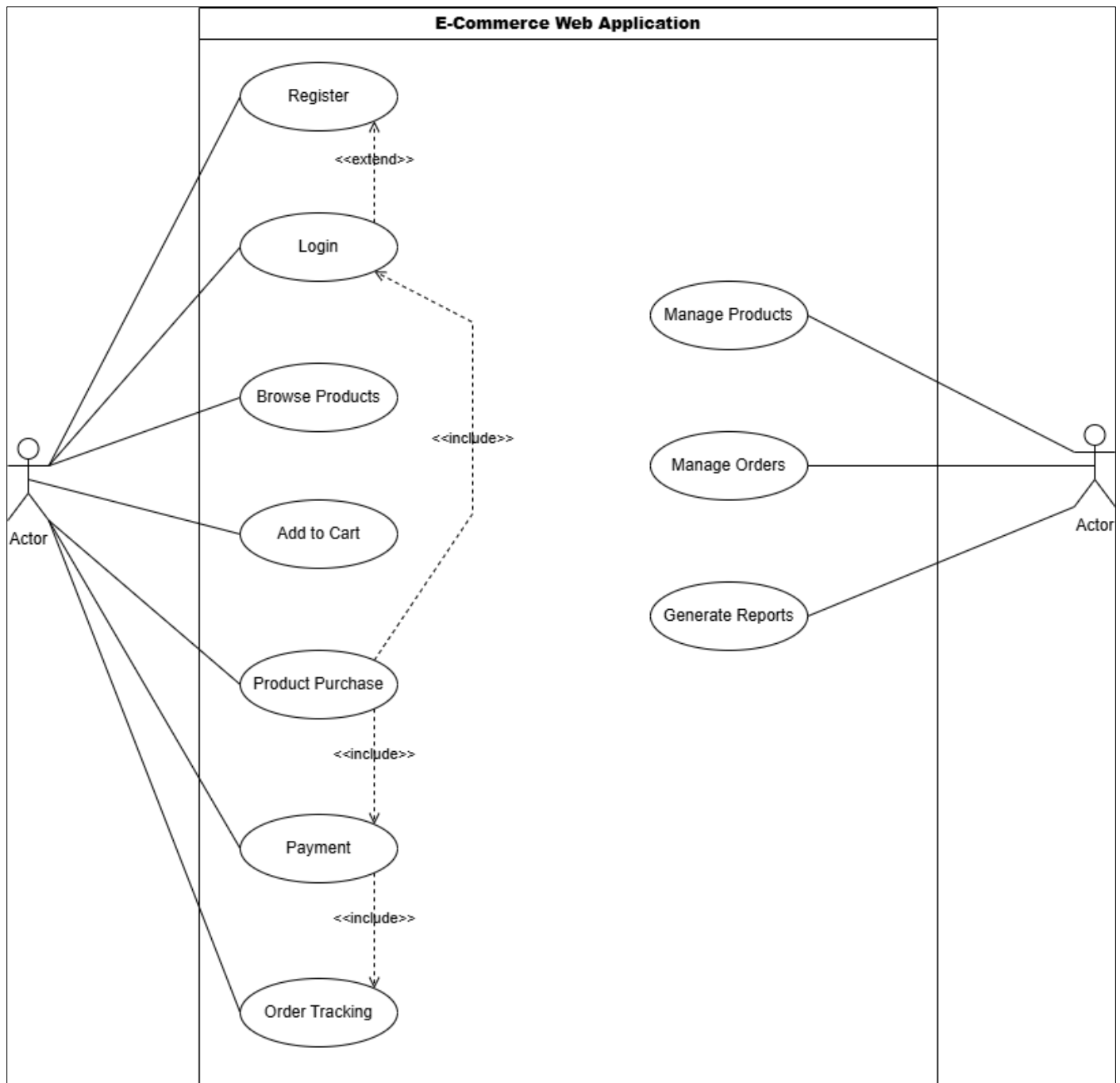
TASK 1 — Data Flow Diagram (DFD)



Explanation:

The Level 1 Data Flow Diagram (DFD) for the e-commerce web application features three main external entities: Customer, Admin, and Payment Gateway. Customers interact with the Web Server to log in, register, search for products, add items to their cart, and input payment details. Meanwhile, the Admin utilizes the Web Server to manage products, view reports, and keep track of orders. The Web Server handles the business logic and connects to the Database to access user, product, and order information. It also forwards payment details to the Payment Gateway, which then sends back a confirmation or a failure response. An Internet boundary delineates the external entities, while an Internal Network boundary safeguards the database and backend processes.

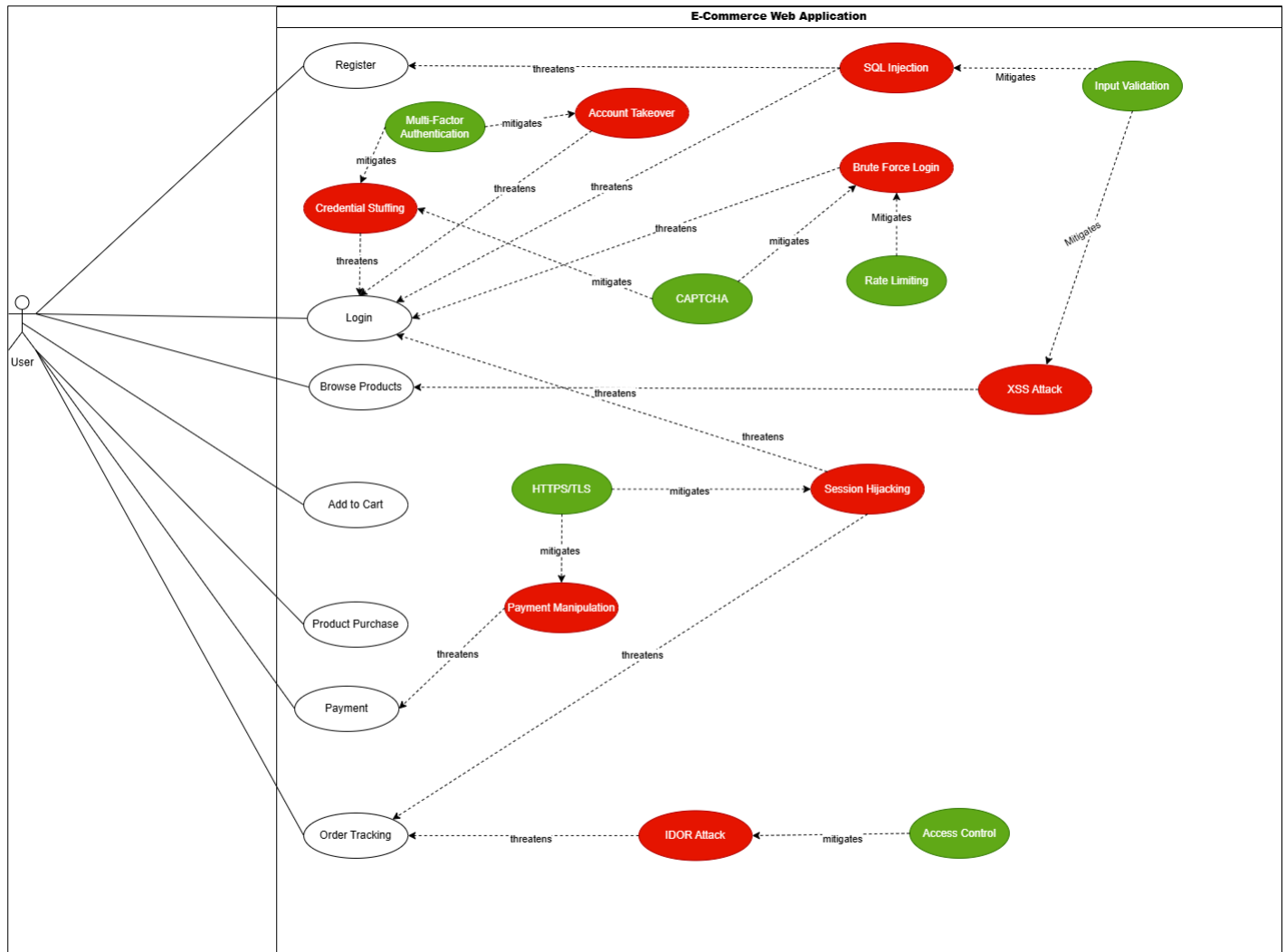
TASK 2 — Use Case Diagram



Explanation

The Use Case Diagram delineates two primary human actors—Customer and Admin—alongside the system actor, the Payment Gateway. Customers have the capability to register, log in, browse products, make purchases, process payments, and track orders. The Product Purchase use case requires user authentication via Login, necessitates that items are added to the cart, and triggers Payment Processing upon completing a purchase. The Admin actor can log in, manage products, view sales reports, and oversee overall system administration. The relationships between use cases demonstrate necessary connections, while extend relationships illustrate optional pathways, such as the registration option available on the login screen for new users.

TASK 3 — Misuse Case Diagram



Explanation

The Misuse Case Diagram presents three potential malicious actors: External Hackers, Malicious Insiders, and Automated Bots. This diagram highlights nine misuse cases that pose threats, including unusual login attempts and manipulation of payment processes. The Login use case encounters risks such as SQL Injection, Brute Force Login, and Credential Stuffing attacks. Payment Processing is susceptible to tampering attempts, and Order Tracking may be compromised through IDOR (Insecure Direct Object Reference) attacks, where alterations to an order ID could expose sensitive data. Mitigation strategies to enhance security encompass Input Validation, Rate Limiting, HTTPS/TLS encryption, and Multi-Factor Authentication.

TASK 4 — Threat Modeling

Primary Model: STRIDE

The STRIDE framework effectively models potential threats within this e-commerce scenario, categorizing web application vulnerabilities into six distinct classes:

Spoofing: Attackers impersonate legitimate users (e.g., credential stuffing).

Tampering: Unauthorized modifications to payment amounts (e.g., altering price parameters).

Repudiation: Users may deny transactions if there are insufficient audit trails.

Information Disclosure: Sensitive customer data can be exposed through SQL injection.

Denial of Service: DDoS attacks may render the site inaccessible.

Elevation of Privilege: Unauthorized access could be gained to admin functionalities.

Secondary Model: DREAD (for risk rating)

The DREAD model is utilized to assess threats based on the following criteria:

Damage: The severity of impact if the threat is realized.

Reproducibility: The ease with which the attack can be duplicated.

Exploitability: The skill level required for an attacker to exploit the vulnerability.

Affected Users: The potential number of users who may be affected.

Discoverability: The ease with which the vulnerability can be identified.

Applied STRIDE + DREAD Table:

Threat	S/T/R/I/D/E	Damage	Reproducibility	Exploitability	Affected Users	Discoverability	Total/50	Priority
SQL Injection on Login	I, T	10	9	7	10	8	44	Critical
Payment Parameter Tampering	T	9	8	6	8	7	38	High
Brute Force Login	S	7	10	9	9	8	43	Critical
Session Hijacking	S, I	8	7	6	8	6	35	High
IDOR on Orders	I	7	8	8	9	7	39	High
XSS on Reviews	T, I	6	7	7	8	6	34	Medium
DDoS on Web Server	D	8	7	5	10	5	35	High

The PASTA framework is primarily suited for larger enterprises that require alignment with overarching business risks, while LINDDUN is oriented towards identifying privacy threats in compliance with GDPR regulations. In contrast, STRIDE is more applicable in this environment, as it specifically addresses web application attacks aligned with distinct threat categories.

The screenshot displays the ZAP application window titled "Untitled Session - Untitled Session - ZAP 2.17.0". The interface includes a menu bar at the top with options like File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. Below the menu is a toolbar with various icons for file operations and analysis. On the left side, there's a sidebar with sections for "Standard Mode", "Sites", "Contexts" (showing "Default Context"), and "History". The main area features a "Welcome to ZAP" message from Checkmarx, explaining that ZAP is an integrated penetration testing tool. It offers three options for new users: "Automated Scan", "Manual Explore", and "Learn More". At the bottom, there's a status bar showing system information like temperature (37°C), time (4:38 PM), and date (16-May-26). A taskbar at the very bottom shows several open applications including a search bar, file explorer, settings, and communication tools.

The screenshot shows the ZAP (Zed Attack Proxy) interface. The main window is titled 'Automated Scan'. It contains a text input field for the URL to attack, which is 'http://testasp.vulnweb.com/'. Below this, there are checkboxes for 'Use traditional spider' (checked) and 'Use ajax spider' (unchecked). The 'Progress' section shows 'Using traditional spider to discover the content'. The bottom panel displays a list of processed URLs and methods.

Processed	Method	URI	Flags
GET	GET	http://testasp.vulnweb.com/showthread.asp?id=3	
GET	GET	http://testasp.vulnweb.com/Login.asp?RetURL=%2Fshowforum%2Easp%3Fid...	
GET	GET	http://testasp.vulnweb.com/showthread.asp?id=4	
GET	GET	http://testasp.vulnweb.com/Register.asp?RetURL=%2Fshowforum%2Easp%3...	
GET	GET	http://testasp.vulnweb.com/Login.asp?RetURL=/Default.asp?	
POST	POST	http://testasp.vulnweb.com/Register.asp?RetURL=%2FTemplate%2Easp%3...	

Scan Initiated

The screenshot shows the ZAP 2.17.0 interface during an automated scan. The 'Automated Scan' window is active, displaying the URL to attack as `http://testasp.vulnweb.com/`, the scan policy as 'Dev Standard', and the use of a traditional spider. The 'Attack' button is highlighted. Below the scan configuration, a progress bar shows the scan is 37% complete. The 'Sent Messages' tab is selected, displaying a table of HTTP requests and responses.

ID	Req. Timestamp	Resp. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Header	Size Resp. Body
1,247	5/16/26, 4:53:17 PM	5/16/26, 4:53:17 PM	POST	http://testasp.vulnweb.com/Register.asp?RetURL=...	500	Internal Server ...	303 ms	196 bytes	1,208 bytes
1,248	5/16/26, 4:53:17 PM	5/16/26, 4:53:17 PM	POST	http://testasp.vulnweb.com/Login.asp?RetURL=%3B	302	Object moved	319 ms	201 bytes	124 bytes
1,249	5/16/26, 4:53:17 PM	5/16/26, 4:53:17 PM	GET	http://testasp.vulnweb.com/Register.asp?RetURL=...	200	OK	304 ms	177 bytes	3,639 bytes
1,250	5/16/26, 4:53:17 PM	5/16/26, 4:53:17 PM	GET	http://testasp.vulnweb.com/showforum.asp?id=%27	500	Internal Server ...	300 ms	196 bytes	1,208 bytes
1,251	5/16/26, 4:53:17 PM	5/16/26, 4:53:17 PM	GET	http://testasp.vulnweb.com/showthread.asp?id=%27	500	Internal Server ...	307 ms	196 bytes	1,208 bytes
1,252	5/16/26, 4:53:17 PM	5/16/26, 4:53:17 PM	GET	http://testasp.vulnweb.com/Logout.asp?RetURL=...	302	Object moved	304 ms	219 bytes	147 bytes
1,253	5/16/26, 4:53:17 PM	5/16/26, 4:53:17 PM	GET	http://testasp.vulnweb.com/Template.asp?item=S...	500	Internal Server ...	305 ms	196 bytes	1,208 bytes

Sites Found:

The screenshot shows the 'Sites' list in ZAP 2.17.0. The list contains the following entries:

- `https://testasp.vulnweb.com`
- `GET: /`
- `http://testasp.vulnweb.com`
- `GET: /`
- `GET: Default.asp`
- `Images`
- `GET: Login.asp(RetURL)`
- `POST: Login.asp(RetURL)(tfUName,tfU`
- `GET: Logout.asp(RetURL)`
- `GET: Register.asp(RetURL)`
- `POST: Register.asp(RetURL)(tfEmail,tfF`
- `GET: Search.asp`
- `GET: Search.asp(tfSearch)`
- `GET: Template.asp(item)`

Alerts:

 Alerts (16)

- >  External Redirect (2)
- >  Path Traversal
- >  SQL Injection (4)
- >  Absence of Anti-CSRF Tokens (5)
- >  Content Security Policy (CSP) Header Not Set (Systemic)
- >  HTTP Only Site
- >  Missing Anti-clickjacking Header (Systemic)
- >  Application Error Disclosure
- >  Cookie No HttpOnly Flag
- >  Cookie without SameSite Attribute
- >  Information Disclosure - Debug Error Messages
- >  Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (Systemic)
- >  Server Leaks Version Information via "Server" HTTP Response Header Field (Systemic)
- >  X-Content-Type-Options Header Missing (Systemic)
- >  Information Disclosure - Suspicious Comments
- >  Session Management Response Identified (2)

Alerts  3  4  7  2 Main Proxy: localhost:8080

Alerts with different severity level:

 History  Search  Alerts  Active Scan  Output  Spider 

 Alerts (16)

- >  External Redirect (2)
- >  Path Traversal
- >  SQL Injection (4)
- >  Absence of Anti-CSRF Tokens (5)
- >  Content Security Policy (CSP) Header Not Set (Systemic)
- >  HTTP Only Site
- >  Missing Anti-clickjacking Header (Systemic)
- >  Application Error Disclosure
- >  Cookie No HttpOnly Flag
- >  Cookie without SameSite Attribute
- >  Information Disclosure - Debug Error Messages
- >  Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (Systemic)
- >  Server Leaks Version Information via "Server" HTTP Response Header Field (Systemic)
- >  X-Content-Type-Options Header Missing (Systemic)
- >  Information Disclosure - Suspicious Comments
- >  Session Management Response Identified (2)

Alerts  3  4  7  2 Main Proxy: localhost:8080

External Redirect
URL: http://testasp.vulnweb.com/Login.asp?RetURL=https%3A%2F%2F6793585459867204226.owasp.org
Risk:  High
Confidence: Medium
Parameter: RetURL
Attack: https://6793585459867204226.owasp.org
Evidence: https://6793585459867204226.owasp.org
CWE ID: 601
WASC ID: 38
Source: Active (20019 - External Redirect)
Alert Reference: 20019-1
Input Vector: URL Query String
Description:
URL redirectors represent common functionality employed by web sites to forward an incoming request to an alternate resource. This can be done for a variety of reasons and is often done to allow resources to be moved within the directory structure and to avoid breaking functionality for users that request the resource at its previous location. URL
Other Info:
The response contains a redirect in its Location header which allows an external URL to be setCurrent Status  0  0  0  0  0  0  0  0  0

 History  Search  Alerts  Active Scan  Output  Spider 

 Alerts (16)

- >  External Redirect (2)
- >  Path Traversal
- >  SQL Injection (4)
- >  Absence of Anti-CSRF Tokens (5)
- >  Content Security Policy (CSP) Header Not Set (Systemic)
- >  HTTP Only Site
- >  Missing Anti-clickjacking Header (Systemic)
- >  Application Error Disclosure
- >  Cookie No HttpOnly Flag
- >  Cookie without SameSite Attribute
- >  Information Disclosure - Debug Error Messages
- >  Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (Systemic)
- >  Server Leaks Version Information via "Server" HTTP Response Header Field (Systemic)
- >  X-Content-Type-Options Header Missing (Systemic)
- > Information Disclosure - Suspicious Comments
- > Session Management Response Identified (2)

Alerts  3  4  7  2 Main Proxy: localhost:8080

Absence of Anti-CSRF Tokens
URL: http://testasp.vulnweb.com/Login.asp?RetURL=%2FTemplate%2Easp%3Fitem%3Dhtml%2Fabout%2Ehtml
Risk:  Medium
Confidence: Low
Parameter:
Attack: <form action="" method="POST">
Evidence: <form action="" method="POST">
CWE ID: 352
WASC ID: 9
Source: Passive (10202 - Absence of Anti-CSRF Tokens)
Input Vector:
Description:
No Anti-CSRF tokens were found in a HTML submission form.
A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application
Other Info:
No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, csrf, csrfSecret, csrf_magic, CSRF_token]Current Status  0  0  0  0  0  0  0  0  0

The screenshot shows the Burp Suite interface. On the left, a list of alerts is displayed, including 'External Redirect (2)', 'Path Traversal', 'SQL Injection (4)', 'Absence of Anti-CSRF Tokens (5)', 'Content Security Policy (CSP) Header Not Set (Systemic)', 'HTTP Only Site', 'Missing Anti-clickjacking Header (Systemic)', 'Application Error Disclosure' (selected), 'Cookie No HttpOnly Flag', 'Cookie without SameSite Attribute', 'Information Disclosure - Debug Error Messages', 'Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (Systemic)', 'Server Leaks Version Information via "Server" HTTP Response Header Field (Systemic)', 'X-Content-Type-Options Header Missing (Systemic)', 'Information Disclosure - Suspicious Comments', and 'Session Management Response Identified (2)'. The right pane shows details for the selected 'Application Error Disclosure' alert, including the URL, risk level (Low), confidence (Medium), parameter, attack type, evidence, CWE ID, WASC ID, source, input vector, and a description of the error message.

Risk Severity

Vulnerability	Risk	CVSS Score	Affected Component	Impact
SQL Injection	High	9.8	Login, Search	Authentication bypass, Data theft
Reflected XSS	High	8.2	Search, Reviews	Session hijacking, Phishing
Cookie No HttpOnly	Medium	6.1	Session Management	Cookie theft via XSS
X-Frame-Options Missing	Medium	5.4	All pages	Clickjacking
Server Version Disclosure	Low	3.7	Response Headers	Information disclosure
Cookie No Secure Flag	Low	4.3	Session Management	Cookie interception
X-Content-Type Missing	Low	3.5	Response Headers	MIME sniffing

- End of Lab Quiz -